



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Microsoft EvilTokens Device Code Phishing Threat Daily Update - 2026-09-23

Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-09-23
Version	1.0
Author	Lost Boys Cyber
Report Type	Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | Microsoft EvilTokens Device Code Phishing Threat Daily Update - 2026-09-23 - Threat Intelligence Report

Published: 2026-09-23 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirements
3. Source Review & Confidence
4. Threat Actor / Campaign Overview
5. Tactics, Techniques, and Procedures
6. Infrastructure and Indicators
7. Victimology and Targeting
8. Detection Engineering
 - 8.1. Detection Logic Summary
9. Threat Hunting
10. MITRE ATT&CK Mapping
11. Risk Assessment
12. Recommended Actions
13. References

Microsoft EvilTokens Device Code Phishing Threat Daily Update - 2026-09-23

> Daily automation refresh: This 2026-09-23 report turns current identity-threat coverage into a finished Lost Boys Cyber report with source-backed analysis, structured tables, detections, and hunt content.

1. Executive Summary

Microsoft's 2026-09-22 EvilTokens research describes device-code phishing in which an attacker initiates a legitimate OAuth device-code flow, delivers the code to a victim through a lure, and obtains tokens when the victim completes authentication. The priority for defenders today is to reduce device-code abuse, monitor anomalous device-code sign-ins, and treat suspicious consent/session behavior as identity intrusion activity rather than ordinary phishing.

2. Intelligence Requirements

Requirement	Answered By This Report
What changed?	Microsoft published current research on EvilTokens and device-code phishing tradecraft.
Who is exposed?	Microsoft Entra ID / Microsoft 365 tenants, help desks, executives, administrators, contractors, and remote users.
What should defenders do today?	Review device-code flow policy, conditional access controls, user education, token/session revocation paths, and identity hunts.
Confidence	High for Microsoft-described technique; medium for organization-specific prevalence.

3. Source Review & Confidence

Source	URL	Confidence
Microsoft Security Blog	https://www.microsoft.com/en-us/security/blog/2026/09/22/unmasking-eviltokens-getting-to-the-root-of-device-code-phishing/	High
Microsoft Entra device code flow documentation	https://learn.microsoft.com/en-us/entra/identity-platform/v2-oauth2-device-code	Medium
CISA phishing guidance	https://www.cisa.gov/secure-our-world/recognize-and-report-phishing	Medium
MITRE ATT&CK phishing technique	https://attack.mitre.org/techniques/T1566/	Medium

4. Threat Actor / Campaign Overview

Device-code phishing is attractive because it abuses a legitimate authentication path and can bypass user expectations about app prompts. The attacker does not need malware execution on the endpoint; successful social engineering can yield OAuth tokens suitable for email access, data theft, persistence through app consent, or follow-on phishing.

5. Tactics, Techniques, and Procedures

TTP	Description	Defensive Relevance
Device-code lure	Victim is told to visit the legitimate device-	User training alone is insufficient; sign-in

	login page and enter an attacker-provided code.	telemetry must be monitored.
Token acquisition	Attacker receives tokens after the victim completes authentication.	Revoke sessions and refresh tokens during response.
Mailbox and cloud data access	Tokens can enable Graph, Exchange, SharePoint, or Teams access depending on scopes.	Hunt for unusual applications, locations, and mailbox activity.
Follow-on phishing	Compromised mailbox or collaboration account can be used to expand access.	Monitor inbox rules, external forwarding, and anomalous sends.

6. Infrastructure and Indicators

Observable Type	Observable / Pattern	Handling Guidance
Atomic IOCs	No durable attacker-owned IOCs were available from public sources for this report.	Focus on identity telemetry and OAuth patterns.
Identity events	Device-code sign-ins, new/rare applications, unusual user-agent/location combinations.	Prioritize admin and high-value users.
Cloud audit events	Consent grants, mailbox rule creation, file access bursts, impossible travel.	Correlate with sign-in risk and session revocation.

7. Victimology and Targeting

Likely victims include enterprises with Microsoft cloud identity, especially users accustomed to help-desk workflows, remote access prompts, collaboration tools, or cross-device authentication. Aviation, aerospace, managed-service, and supplier environments should treat identity compromise as a supply-chain risk because trusted accounts often bridge tenant, contractor, and partner systems.

8. Detection Engineering

8.1. Detection Logic Summary

Signal	Telemetry Source	Analytic Goal
Device-code sign-in from unusual geography or ASN	Entra ID SigninLogs	Identify social-engineered token issuance.
Rare OAuth application or unexpected resource access	Entra audit/app logs	Detect token use after the phish.
Mailbox rule or forwarding change after device-code sign-in	Exchange audit logs	Surface account takeover behavior.
<pre> SigninLogs where TimeGenerated > ago(14d) where AuthenticationProtocol has_any ('deviceCode','Device Code') or AppDisplayName has_any ('Microsoft Authentication Broker','Azure CLI','Microsoft Office') summarize Signins=count(), IPs=make_set(IPAddress, 50), Countries=make_set(Location, 20), Apps=make_set(AppDisplayName, 20) by UserPrincipalName, AuthenticationProtocol where Signins > 3 or array_length(Countries) > 1 or array_length(IPs) > 5 order by Signins desc </pre>		
title: Suspicious Cloud Identity Device Code Flow Activity		

```

status: experimental
description: Flags unusual device-code authentication activity that may indicate EvilTokens-style phishing.
logsource:
  product: azure
  service: signinlogs
detection:
  selection:
    AuthenticationProtocol|contains:
      - 'device'
  condition: selection
level: medium

```

9. Threat Hunting

Hypothesis	Query Focus
A user completed a device-code sign-in from a suspicious prompt.	Device-code authentication followed by new location/app access.
The attacker used tokens to access mail or files.	Graph/Exchange/SharePoint access after the sign-in.
Persistence was established through mailbox or app configuration.	Inbox rules, forwarding, OAuth consent, service principal changes.
<pre> AuditLogs where TimeGenerated > ago(14d) where OperationName has_any ('Consent to application','Add app role assignment to service principal','Update application','Add service principal') project TimeGenerated, OperationName, TargetResources, InitiatedBy, Result order by TimeGenerated desc </pre>	
<pre> OfficeActivity where TimeGenerated > ago(14d) where Operation has_any ('New-InboxRule','Set-Mailbox','Add-MailboxPermission','FileDownloaded','MailItemsAccessed') summarize Events=count(), Ops=make_set(Operation, 20) by UserId, ClientIP, Workload where Events > 10 order by Events desc </pre>	

10. MITRE ATT&CK Mapping

Technique	Name	Evidence / Rationale
T1566	Phishing	Victim receives a lure to complete a legitimate device-code flow.
T1528	Steal Application Access Token	Technique results in attacker token possession.
T1114	Email Collection	Tokens can enable mailbox access.
T1098	Account Manipulation	Consent grants, rules, or configuration changes may follow.

11. Risk Assessment

Risk	Likelihood	Impact	Notes
Account takeover	High	High	Technique targets cloud identity directly.
Data theft	Medium/High	High	Token scopes may allow

			mail/file access.
Business email compromise	Medium	High	Compromised accounts can send trusted lures.
Supplier pivot	Medium	Medium/High	Partner accounts can cross organizational boundaries.

12. Recommended Actions

Priority	Owner	Action
1	IAM	Review whether device-code flow is required; restrict where feasible.
2	SOC	Deploy hunts above and alert on anomalous device-code sign-ins.
3	Cloud security	Review consent policies and require admin approval for risky apps.
4	IR	Prepare token/session revocation and mailbox audit playbooks.
5	Awareness	Train users that legitimate Microsoft pages can still be abused when the code came from an attacker.

13. References

- [1] Microsoft Security Blog: <https://www.microsoft.com/en-us/security/blog/2026/09/22/unmasking-eviltokens-getting-to-the-root-of-device-code-phishing/>
- [2] Microsoft Entra device code flow documentation: <https://learn.microsoft.com/en-us/entra/identity-platform/v2-oauth2-device-code>
- [3] CISA phishing guidance: <https://www.cisa.gov/secure-our-world/recognize-and-report-phishing>
- [4] MITRE ATT&CK phishing technique: <https://attack.mitre.org/techniques/T1566/>